

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-07-10 · PR: [#70](#) · Branch: `fix/depSCAN-20260710-060240` ·
Health Score: **37 / 100** Grade D — high risk

Executive summary

- **24** dependencies scanned · **86** CVE instances found at baseline (**18** CRITICAL / **48** HIGH / **19** MEDIUM / **1** LOW).
- **Stage 3 remediation (PR #70)**: 6 dependencies bumped, 1 typosquatted coordinate removed, 1 untrusted HTTP mirror removed. Result: **86** → **17** unresolved CVE instances (per the Stage 1/3 scanner's own re-count) — CRITICAL 18 → 0, HIGH 48 → 11, MEDIUM 19 → 6, LOW 1 → 0.
- **Stage 4 merge gate (fresh Syft SBOM + Grype re-scan)**: verdict BLOCK. Tests pass; two independent blocking findings remain (jackson-databind residual HIGH CVEs, mysql-connector-java license + CVE). Full detail below.
- **Tracking issues opened this run**: [#71](#) (jackson-databind MAJOR_REVIEW), [#72](#) (NEEDS_VERIFICATION follow-up); mysql-connector-java cross-referenced to existing [#64](#) / [#68](#) rather than duplicated.
- **PR #70 must not merge yet** — gate is BLOCK until [#71](#) and the [#64](#)/[#68](#) mysql-connector-java decision are resolved and the gate is re-run.

Stage 1–2 — Scan & risk score (baseline)

Metric	Count
Dependencies scanned	24
Total CVE instances	86
CRITICAL instances	18
HIGH instances	48
MEDIUM instances	19
LOW instances	1
Outdated dependencies	8
License violations	1 (mysql-connector-java, GPL-2.0-with-FOSS-exception)
License warnings	1
Supply-chain alerts	1 typosquat + 1 untrusted mirror

Top risks (weighted $0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$), ranked:

Coordinate	Risk	Band	Top CVE
com.fastxml.jackson.core:jackson-databind (typosquat)	2.8*	CRITICAL	supply-chain (non-existent coordinate)
org.apache.logging.log4j:log4j-core / log4j-api	7.8	HIGH	CVE-2021-44228 (Log4Shell, 10.0)
com.fasterxml.jackson.core:jackson-databind	7.8	HIGH	CVE-2019-14379 (9.8)
mysql:mysql-connector-java	7.2	HIGH	CVE-2023-22102 (8.3) + GPL-2.0 violation
com.google.protobuf:protobuf-java (transitive)	7.0	HIGH	CVE-2022-3509 (7.5)
com.google.guava:guava	5.5	MEDIUM	CVE-2023-2976 (5.5)

* Supply-chain removals are prioritized above the formula-derived score regardless of weighted value.

Full detail: `depscan-report.json` , `depscan-risk-report.json` , `depscan-reports/CVE-Report.md` , `depscan-reports/Risk-Scoring-Report.md` .

Stage 3 — Auto-remediation (PR #70)

Dependency	Old version	New version	CVEs cleared
org.apache.logging.log4j:log4j-core	2.14.1	2.17.1	CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), CVE-2021-44832 (6.6), CVE-2021-45105 (5.9)
org.apache.logging.log4j:log4j-api	2.14.1	2.17.1	same 4 CVEs
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.9.10.8	56 CVEs (14 CRITICAL / 37 HIGH / 5 MEDIUM) — final consolidated 2.9.x patch
com.google.guava:guava	24.1.1-jre	32.0.0-jre	CVE-2023-2976 (5.5), CVE-2020-8908 (3.3)
commons-io:commons-io	2.4	2.14.0	CVE-2021-29425 (4.8), CVE-2024-47554 (4.3)
org.apache.commons:commons-lang3	3.4	3.18.0	CVE-2025-48924 (5.3)
com.fastxml.jackson.core:jackson-databind (typosquat)	2.9.8	removed	n/a — supply-chain
internal-untrusted-mirror (plaintext HTTP repo)	present	removed	n/a — supply-chain

Before → after (Stage 1/3 scanner re-count):

Metric	Before	After	Change
CRITICAL instances	18	0	-18 (100%)
HIGH instances	48	11	-37 (77%)
MEDIUM instances	19	6	-13 (68%)
LOW instances	1	0	-1 (100%)
Typosquatted coordinate	1	0	removed
Untrusted HTTP mirror	1	0	removed
License violation (GPL-2.0)	1	1	unresolved — MAJOR_REVIEW

Left untouched (human follow-up), per the remediation skill's "no silent auto-apply of unsafe fixes" rule:

- `mysql:mysql-connector-java:8.0.30` — GPL-2.0-with-FOSS-exception license violation + CVE-2023-22102/CVE-2023-21971; no same-coordinate patch clears the CVE, and the structural fix (rename to `com.mysql:mysql-connector-j`) doesn't clear the license family either. Routed to existing tracking issues #64/#68.
- `com.google.protobuf:protobuf-java:3.19.4` (transitive via mysql) — 4 HIGH + 1 MEDIUM CVEs, tied to the mysql decision above.
- `log4j` CVE-2026-34477/34479/34480/34481 , CVE-2025-68161 — scanner's `fix_version` was an open-ended `"2.17.1+(verify latest 2.x)"` ; bumped to the concrete `2.17.1` (clears Log4Shell) but these five newer IDs need separate verification (now tracked in #72).

Build verification: `mvn test package` — **PASS** (2/2 tests). `mvn dependency:tree` re-check confirmed the typosquat coordinate is gone and all target versions resolved as declared.

Full detail: `depscan-reports/CVE-Report.md` , `depscan-reports/Risk-Scoring-Report.md` .

Stage 4 — Merge gate verdict: BLOCK

A fresh Syft SBOM + Gripe supply-chain audit was run independently against PR #70's head (source SHA `f6165874`), separate from the Stage 1/3 scanner re-count above — the two tools use different CVE-matching methodologies, hence the differing instance counts.

Check	Result
<code>mvn test package</code> (build + tests)	PASS (2/2)
Typosquat check	PASS — confirmed removed
Untrusted-source check	PASS — confirmed removed
OWASP / CVE re-scan (originally targeted findings)	PASS
Supply-chain audit (Syft + Gripe)	BLOCK — 2 blocking findings

Blocking findings:

#	Coordinate	Finding	Required fix
1	<code>com.fasterxml.jackson.core:jackson-databind:2.9.10.8</code>	3 unresolved HIGH CVEs: CVE-2020-36518, CVE-2022-42003, CVE-2022-42004	Bump to <code>>=2.12.7.1</code> — tracked in #71
2	<code>mysql:mysql-connector-java:8.0.30</code>	Denied GPL-2.0-with-FOSS-exception license + CVE-2023-22102 (HIGH, no fix in this coordinate lineage)	Human legal/license decision (e.g. migrate to <code>com.mysql:mysql-connector-j</code> <code>>=8.2.0</code>) — tracked in #64 / #68

Non-blocking warnings (tracked in [#72](#)):

- `org.apache.logging.log4j:log4j-core / log4j-api:2.17.1` — 3 MEDIUM CVEs fixed in the 2.25.x line.
- `com.fasterxml.jackson.core:jackson-databind:2.9.10.8` — 1 further MEDIUM CVE with no fix currently available.

Gate verdict posted as a PR review (COMMENT event — REQUEST_CHANGES is not permitted on one's own PR): <https://github.com/sathiskumarperumal/dependency-supplychain-demo/pull/70#pullrequestreview-4669106285>

PR #70 is not merged. It should remain open until [#71](#) and the `mysql-connector-java` decision ([#64](#)/[#68](#)) are resolved and the gate is re-run clean.

Full detail: `depscan-supplychain-audit.json` , `target/sbom.cdx.json` .

Tracking issues opened this run

#	Priority	Title	One-line summary
#71	MAJOR_REVIEW	<code>jackson-databind 2.9.10.8</code> → <code>>=2.12.7.1</code>	Blocks PR #70's merge gate; needs a version-line jump (not a same-line patch) plus compatibility verification.
#72	NEEDS_VERIFICATION	Re-scan <code>log4j 2.25.x</code> MEDIUM CVEs + <code>jackson-databind</code> residual MEDIUM CVE	Non-blocking; follow-up re-scan once #71 and #64 / #68 land.

Cross-referenced, not duplicated: `mysql-connector-java`'s GPL-2.0 license violation + CVE-2023-22102 is already thoroughly tracked in existing open issues [#64](#) (license) and [#68](#) (CVE ineffectiveness + migration path to `com.mysql:mysql-connector-j`) — no new issue was opened for it this run to avoid adding to the ~15 prior duplicate `mysql-connector-java` issues already open in this repository's history.

Health score breakdown

start at 100		
- 8 × 4	unresolved HIGH CVEs (Stage 4 Grype count: 3 jackson-databind + 1 mysql)	= -32
- 2 × 4	unresolved MEDIUM CVEs (Stage 4 Grype count: 3 log4j + 1 jackson-databind)	= - 8
- 10 × 2	supply-chain BLOCK findings (jackson-databind HIGH, mysql license)	= -20
- 3 × 1	outdated major-version-line dependency (mysql-connector-java migration owed)	= - 3
		score = 37 / 100

Score	Grade
37 / 100	Grade D — high risk

This run's own baseline (Stage 1, before PR #70) was **0/100** — 18 unresolved CRITICAL CVEs alone floor the formula. Stage 3's remediation lifted the score to **37/100**, but the gate's BLOCK verdict means the project is not yet in a mergeable, healthy state.

Projected once #71 and the mysql-connector-java decision (#64/#68) land: clearing the jackson-databind HIGH CVEs and the mysql license/CVE block would remove both BLOCK deductions and the 4 HIGH-CVE deduction, projecting to roughly **75–80/100 (Grade B)** — the remaining gap would be the log4j 2.25.x MEDIUM follow-up (#72) and jackson-databind's one no-fix-available MEDIUM CVE.

Trend vs. previous run

The most recent prior `Audit-Trail-Report.md` on record (generated 2026-06-10, a different demo scenario with 9 dependencies / 13 CVEs) scored **0/100 (Grade D)** at its own baseline. Comparing like-for-like within *this* run:

Point in this run	Score	Grade
Stage 1 baseline (before PR #70)	0 / 100	D
Stage 4 gate (current, PR #70 open, BLOCK)	37 / 100	D
Projected after #71 + #64/#68 resolved	~75–80 / 100	B

CVEs resolved this cycle: 86 → 17 unresolved instances (Stage 1/3 count) / 69 CVE instances cleared; 2 supply-chain findings (typosquat, untrusted mirror) fully removed; 2 remain blocking (tracked in #71, #64/#68); 2 remain as non-blocking follow-up (tracked in #72).

Tests

- `mvn test` package : **2 / 2 passed**
- Pre-existing, out-of-scope failure: the JaCoCo 80%-line-coverage gate still fails `mvn verify` (tracked separately, unrelated to these dependency changes — confirmed via `mvn clean test`, which passes clean).

State of supply-chain hygiene — one-paragraph summary

This run cleared every CRITICAL and the large majority of HIGH/MEDIUM CVEs in a single consolidated PR (#70), and permanently removed both active supply-chain threats (a typosquatted Jackson coordinate and a plaintext-HTTP dependency mirror) — a strong result given the starting point of 86 CVE instances across 24 dependencies. However, the project is **not yet mergeable**: an independent Stage 4 re-scan caught two things Stage 3 missed — three further jackson-databind HIGH CVEs that need a version-line jump beyond the initially-chosen patch (#71), and a pre-existing GPL-2.0 license violation on mysql-connector-java that has been surfaced repeatedly across this repository's history (#64, #68) and still awaits a human legal decision. Both are now clearly tracked with actionable next steps, and a lower-priority follow-up scan (#72) is queued for once those land — at which point the health score is projected to jump from 37 to the mid-to-high 70s.

Aggregated from `depscan-report.json`, `depscan-risk-report.json`, `depscan-supplychain-audit.json`, `depscan-reports/CVE-Report.md`, and `depscan-reports/Risk-Scoring-Report.md`. Generated by the Dependency & Supply-Chain Plugin — Stage 5 (Audit Trail).